

Delice

Politique d'Analyse des Journaux d'Audit des Événements d'Application
Détection des accès non autorisés aux données de la plateforme

journal d'audit-22.e.ii — Meta App Review

★ CONDITIONS META REQUIRES — SURLIGNÉES ET ENCADRÉES

- ✓ **Activité d'authentification non autorisée ou anormale** → Section 3 (fail2ban temps réel + rapport SSH)
- ✓ **Défaillances du contrôle d'accès ou tentatives d'élévation de privilèges** → Section 3 (HTTP 401/403 + auditd)
- ✓ **Signes d'exploitation ou d'abus de l'application** → Section 3 (sondes .env/.git, Laravel ERROR)
- ✓ **Modes d'accès ou d'extraction de données inhabituels** → Section 3 (IPs à fort volume, endpoints API)
- ✓ **Examen au moins tous les 7 jours** → Section 2 (cron lundi 08:00 UTC, période glissante 7 jours)

1. Objectif et périmètre

Cette politique décrit le processus automatisé d'analyse des journaux d'audit des événements d'application de BantuDelice (bantudelice.cg), afin de détecter les indicateurs d'accès non autorisé aux données de la plateforme, qu'il s'agisse d'accès avérés ou tentés.

Couche 1 — Temps réel

Outil **fail2ban** (daemon actif)

Fréquence ✓ **Continue (24/7)**

Cible **Authentification SSH**

Action **Ban automatique IP**

Couche 2 — Hebdomadaire

Outil **security-audit.sh** (cron)

Fréquence ✓ **Chaque lundi 08:00 UTC**

Période **7 jours glissants**

Action **Rapport + archivage log**

2. Processus automatisé — Fréquence et déclenchement

★ CONDITION META : EXAMEN AU MOINS TOUS LES 7 JOURS — SURLIGNÉE

Le script `/opt/bantudelice/scripts/security-audit.sh` s'exécute automatiquement chaque lundi à 08:00 UTC via cron, couvrant une période glissante de 7 jours. Un rapport horodaté est généré et archivé dans `storage/logs/security-audit-YYYY-MM-DD.log`. fail2ban analyse les journaux d'authentification en temps réel, 24h/24.

```
root@vps-0e8f1563:~# crontab -l | grep security
0 8 * * 1 /opt/bantudelice/scripts/security-audit.sh >> /opt/bantudelice/storage/logs/security-audit-cron.log 2>&1
# ↑ Chaque lundi (1) à 08:00 UTC — période glissante 7 jours — Meta compliance

root@vps-0e8f1563:~# systemctl is-active fail2ban
active # analyse SSH en temps réel 24/7
```

3. Indicateurs analysés — Correspondance Meta

★ CONDITION META : 4 CATÉGORIES D'INDICATEURS — SURLIGNÉES

Le rapport hebdomadaire couvre les 4 catégories d'indicateurs d'accès non autorisé listés par Meta : (1) authentification anormale, (2) défaillances contrôle d'accès, (3) exploitation applicative, (4) patterns d'accès inhabituels.

Indicateur Meta	Section rapport	Sources analysées	Outil
Authentification non autorisée / anormale	[1] AUTHENTICATION FAILURES	/var/log/auth.log fail2ban status	fail2ban + script
Défaillances contrôle d'accès / élévation de privilèges	[2] ACCESS CONTROL FAILURES	Nginx access.log (HTTP 401/403/4xx)	script + auditd
Exploitation ou abus de l'application	[3] APPLICATION ERRORS	laravel-YYYY-MM-DD.log Nginx (sondes .env/.git)	script
Modes d'accès ou d'extraction inhabituels	[4] UNUSUAL DATA ACCESS	Nginx access.log (top IPs, top endpoints API)	script

4. Premier rapport généré — Résultats du 3 juin 2026

Generated : 2026-06-03 23:14:09 UTC — Period: 2026-05-27 → 2026-06-03

[1] AUTHENTICATION FAILURES

SSH failed attempts : **6 275** ← brute force détecté et bloqué
IPs permanently banned : **50** ← ban automatique fail2ban
Top attacking IP : **2.57.122.177** (729 tentatives)

[2] ACCESS CONTROL FAILURES (HTTP)

HTTP 404 Not Found : **16** ← tentatives accès ressources inexistantes
HTTP 5xx Server Error : 1
Top IPs 4xx errors : 91.238.67.159 (8), 213.165.35.72 (8)

[3] APPLICATION ERRORS & EXPLOITATION

2026-05-31 : **134** ERROR/CRITICAL entries
2026-06-02 : **1 609** ERROR/CRITICAL entries ← spike analysé (permissions cache)
2026-06-03 : 295 ERROR/CRITICAL entries
Sensitive path probes : **16** tentatives (.env, .git, /admin)

[4] UNUSUAL DATA ACCESS PATTERNS

High-volume IPs (>100 req) : none ← aucun pattern anormal détecté

[5] SUMMARY

STATUS: **MODERATE activity** — 6 291 indicateurs détectés — plage normale
Report: /opt/bantudelite/storage/logs/security-audit-2026-06-03.log

5. Architecture des outils d'analyse

Outil	Type	Fréquence	Journaux analysés	Action automatique
fail2ban	Démon système	Temps réel	/var/log/auth.log	Ban IP automatique (15 min / permanent)
auditd	Framework audit Linux	Temps réel	Syscalls, fichiers logs, commandes root	Alerte dans /var/log/audit/audit.log
security-audit.sh	Script cron	Hebdomadaire (lundi 08h UTC)	auth.log, Nginx access.log, Laravel logs	Rapport structuré + archivage 14 jours
Nginx	Reverse proxy	Temps réel	Toutes requêtes HTTP/HTTPS	HTTP 4xx/5xx, blocage .env (403)

6. Procédure de revue et escalade

★ **CONDITION META : REVUE ≥ 7 JOURS — PROCÉDURE SURLIGNÉE**

Chaque rapport hebdomadaire est examiné par l'équipe technique BantuDelice. Un score SUMMARY est calculé automatiquement : LOW (<10 indicateurs) / MODERATE (10-100) / REVIEW RECOMMENDED (>100). Si le statut est REVIEW RECOMMENDED, une investigation manuelle est déclenchée dans les 24h.

Statut rapport	Seuil	Action requise	Délai
LOW	< 10 indicateurs	Archivage — aucune action	—
MODERATE	10 – 100 indicateurs	Revue hebdomadaire standard	7 jours
REVIEW RECOMMENDED	> 100 indicateurs	Investigation manuelle obligatoire	24 heures
CRITICAL	Accès réussi non autorisé	Incident response immédiate	4 heures

★ **CONCLUSION — SURLIGNÉE**

BantuDelice utilise un processus automatisé multi-couches pour analyser les journaux d'audit applicatifs : fail2ban (temps réel), auditd (temps réel), et un script cron hebdomadaire (chaque lundi 08:00 UTC) couvrant les 4 catégories d'indicateurs Meta. L'exigence de revue au moins tous les 7 jours est satisfaite par le cron hebdomadaire automatique. Le premier rapport a été généré le 3 juin 2026 à 23:14 UTC.